

Assets Analysis

Semir Hot, Harrison Maksimik

March 10, 2024

Contents

1	Assets List	1
2	Vulnerability Enumeration	2
2.1	Point of Sale (Modisoft)	2
2.2	Credit Card Machine (Verifone)	3
2.3	Office Computer	4
2.4	Network Router	4
2.5	Wireless Access Point	4
2.6	Email System	5
3	Risk Ranking Worksheet	5
4	Mitigation Strategy	6
4.1	Access Control	6
4.2	Antivirus	6
4.3	Intrusion Detection System	7
4.4	Backups	7
4.5	Forensic Readiness	7
4.6	Immutable Systems	7

1 Assets List

Table 1: Assets, Access Classification, Impact on Business

Category	Asset	Classification	Impact
Continued on next page			

Continued from previous page

Category	Asset	Classification	Impact
People	Cashiers		
	Janitors		
	Customer Service		
	Human Resources		
	Manager		
	Car Wash Attendant		
	Store Clerk		
Hardware	Network Router	Public	Critical
	Wireless Access Point	Private	High
	CCTV Cameras	Private	Medium
	DVR	Private	Medium
	Gas Pumps	Public	Critical
	Point of Sale	Confidential	Critical
	Air Compressor	Public	Low
	Lottery ticket system	Private	High
	Office Computer	Confidential	High
	Backup Servers	Confidential	High
Software	Router Operating System	Private	High
	Office Computer OS	Private	High
	Backup Software	Confidential	High
	CCTV Monitoring Software	Private	Medium
	Point of Sale System	Confidential	Critical
	Inventory System	Confidential	Medium
	Mobile Application (Modisoft)	Confidential	High
	Email System	Confidential	High
Business Partners	Firewall	Confidential	High
	Gasoline Distributor	Confidential	Critical
	Store Goods Distributor	Private	High
	Car Wash Supplies Distributor	Private	High
	Contractor for Modisoft	Private	Medium
Networking	Contractor for Network Design	Private	High
	Off-site Backups	Confidential	High
	Remote DVR Access	Private	Medium
Continued on next page			

Continued from previous page

Category	Asset	Classification	Impact
Data	Private Wireless Access	Private	High
	Local Backups	Confidential	High
	Local Transactions Database	Confidential	Critical
	Customer Financial Information	Confidential	Critical
	Customer Contact Information	Confidential	Critical
	Account Information	Confidential	High
	Sales Records	Confidential	Medium
	Business Partner Contact Info	Private	Medium
	Inventory Data	Private	Medium

2 Vulnerability Enumeration

2.1 Point of Sale (Modissoft)

Point of Sale can be attacked in such a way that an attacker can lock the software on the POS using ransomware to completely shut down the business. It is worth noting that some ransomware might only make usage of the system challenging, but not encrypt data; in this scenario, the attacker would likely request a ransom for access to the machine back, rather than the data. Our organization will consider this type of ransomware, as much of the data storage is handled by a third-party.

The POS runs bespoke software which includes a login to access both the general user side of the POS, as well the back-end of the software for managers and IT personnel. With the user login, the attacker would be able to see all previous sales, and can do basic functions such as write up transactions. A compromise to this account would not lead to serious damage. A compromise to the Manager login, however, could lead to serious damage. With access to this account, the attacker could erase the contents of the register, financial data and other sensitive information, such as inventory, customer data and so on.

The software also provides remote functionality which can be logged in to with a computer; the method to access this remote management system is a secret link known only to the owner. With said risks above there is one way to ensure an attacker does not have access to this plan and that is having a good password policy. We ran though the system and set a requirement in place to have a strong password and we also made it to require a new password

every month that is not one that was used previously. With this an attacker will have a much harder time getting to information and access levels that are considered to be sensitive. On the other hand we must also consider Insider threats here as all employees have access to the user side of things on the POS, what we have done is we created a new login for all employees that run the register and this way if they make an action on the POS it will be tracked and all actions are tied to a person. Now that all of their actions are tracked and noted down then the owner can go into his account and can see what the users are doing and if they are doing something they shouldn't be doing, he can identify who it was and what they did. In addition to this, we ensured that normal users did not have access to sensitive information such as back end operation and if in the case the employee wants to do malicious action their options are very limited and minimize the damage while still ensuring proper work flow and freedom.

2.2 Credit Card Machine (Verifone)

After some research we discovered that CC machines are run through Verifone and all the transactions are run through verifone and at the end of the day all the money that owner is owed is run back to the owner with fees and costs subtracted from the company. We initially thought that the owner ran these transactions himself and was forced to store customer data on-premises but we figured out that verifone runs it and ensures proper security measures are taken to keep customers safe. While this is true we did notice that across the United States there are many people that will attach CC skimmers to these machines so we implemented a policy such that at the start of every shift the manager will check the integrity of the machine and ensure that there is no such thing attached to the machine and the machines are untouched and safe to use.

2.3 Office Computer

The office computer from what we have understood is not used very much, the owner tracks most things on paper and does most of the business tracking on a paper and keeps most sensitive things up to the providers such as verifone. Although this is the case we still wanted to ensure that the computer stays safe and avoids any attacks such as ransomware. We set password policies and ensure that the computer was set up in a way where it would be protected from all hackers and incoming attacks for the most part. Since the owner is the only one that uses the computer we ran him

through a phishing briefing that is slightly different to that of the one we ran the employees through and ensured he knew about all attacks that can occur over email and the internet.

2.4 Network Router

The network router provides routing to each of the different information systems on the network, including the CCTV/DVR system, some of the Point of Sale back-end, the office computer, lottery ticket system and backup server. It's important to note that router operating systems in general can also be the target of attacks and malware. The impact of a ransomware attack, in particular, would be a denial a service to the information systems connected to the network. An attack like this could be the result of several different types of vulnerabilities, such as a direct software exploit to the router's operating system, weak authentication in the router's login, or an attacker could even find a way through the firewall by piggybacking off of vulnerable open ports.

2.5 Wireless Access Point

The wireless access point, similar to the network router, can be the target of ransomware or other attacks which could lead to a denial of service to the organization's information systems. Additionally, however, the access point can also be used as an attack vector for a ransomware infection. For example, by sniffing unencrypted network traffic, an attacker may be able to find information which could be used to gain access to the organization's information systems. Alternatively, an "Evil Twin" attack could be used to trick a user with network access into downloading a piece of ransomware or other malicious software.

2.6 Email System

Perhaps the most prevalent vector for ransomware, or information security breaches in general for that matter, is email phishing. An attacker may be able to trick an employee of our organization into downloading and executing a malicious piece of software that contains ransomware. In order to perform this social engineering attack, an attacker may spoof their email address to look like the message came from a legitimate source. If an attacker is specifically targeting our organization, they might research an employee whom they consider particularly susceptible in order to send a much more convincing personalized email; this is a process known as spear phishing. Another

potential vector, which may be even more destructive to our organization, is a failure of authentication, where an attacker finds a way to log into a valid email account in our organization and then send a malicious email from an official email address. In such an attack, the attacker would also be able to scrape some potentially sensitive information from the compromised email account even if the ransomware attack is unsuccessful.

3 Risk Ranking Worksheet

Table 2: L=Likelihood, I=Impact, RRF=Risk-Rating Factor

Asset	Vulnerability	L	I	RRF
Email Service	Phishing	5	4	20
Network Router	Software Exploit	3	4	12
Network Router	Weak Authentication	3	3	9
Network Router	Denial of Service	4	3	12
Firewall	Open ports/services	4	2	8
Wireless AP	Denial of Service	4	2	8
Wireless AP	Sniffing	3	2	6
Wireless AP	Evil Twin	1	4	4
Point of Sale	Denial of Service	2	5	10
Point of Sale	Weak Authentication	4	3	12
Point of Sale	Vulnerable Remote Login	5	4	20
Office Computer	Network Connection	1	3	3
Office Computer	Weak Authentication	3	3	9
CC Machine	Service Provider Vulnerability	1	4	4
CC Machine	Denial of Service	1	5	5
CC Machine	Weak Authentication	2	5	10
CCTV/DVR	Weak Authentication	3	1	3
CCTV/DVR	Denial of Service	1	1	1

4 Mitigation Strategy

4.1 Access Control

Access control will be a large component of our mitigation strategy for ransomware. By controlling access to files across the systems in our organization, we can minimize the impact that ransomware would have in the event that

one system is compromised. The exact specifications of the access control policies use will differ based on the system, so system-specific policies should be consulted for the implementation of this security control. Our organization will likely start out with a simple RBAC-style access control model, with a plan to upgrade to a more robust and expandable system in the future. For this reason, the underlying access control software should be ABAC-based (attribute-based access control), with RBAC implemented on top of it.

4.2 Antivirus

Another critical component of our organization's mitigation strategy is reliable antivirus software. Antivirus software can be used to detect known malicious software, and either prevent that software from running, or alert system administrators to the threat. This software needs to be kept up-to-date in accordance with the issue-specific policy, and the requirements for antivirus software on different system platforms should be consulted from the issue-specific policy as well before implementation.

4.3 Intrusion Detection System

The first step to mitigating a ransomware attack is determining that an attack has happened, and how it happened. An adequate IDS should also be implemented as specified in the ransomware issue-specific policy section. Such a system should be capable of alerting system administrators to any suspicious activities such as unusual network traffic or large amounts of data being written (this could be the encryption of data).

4.4 Backups

In some cases, there may not be any clear route to recovering data after a ransomware attack. In order to mitigate damages in these cases, our organization must ensure that proper backups are being kept regularly, and in a space, time and cost effective manner. The specifications for our organization's backup procedures can be found in the ransomware issue-specific policy.

4.5 Forensic Readiness

Recovering from ransomware can be very costly for our organization; replacement of assets, down-time, implementation of additional security controls, and extra consultancy could easily be a critical loss for our organization.

Thus, a plan to remedy these losses in a court of law should be kept for cases in which legal action is a sensible option. In order to submit evidence that is admissible in court, it is critical that certain measure be taken to ensure forensic readiness and competency. More details about our organization's procedures can be found in the ransomware issue-specific policy.

4.6 Immutable Systems

While our organization has no current policy in place for using immutable systems to mitigate ransomware attacks, recent technology in this field should be assessed at a later date as systems are replaced with newer hardware and/or software. An immutable system can prevent invasive changes being made by any user; while this has unfortunate consequences for the speed at which information systems can be modified and updated by security and IT personnel, the security benefits are worth investigating for future systems.